

Enterprise Vendor Risk Policy

All vendors must be reviewed before they receive access to company systems, customer data, employee data, regulated data, or production environments. The vendor owner must provide a business justification, system access description, data classification, contract status, and support model.

High risk vendors include vendors that access customer data, payment data, health data, production APIs, privileged administration features, encryption keys, or regulated reporting systems. High risk vendors require approval from security, privacy, legal, procurement, and the business data owner before access is granted.

Medium risk vendors include vendors that access internal analytics, operational dashboards, non-production environments, or anonymized business data. Medium risk vendors require approval from security and the business owner.

Low risk vendors include vendors that only receive public information or provide non-integrated advisory services. Low risk vendors require procurement review and business owner approval.

Required evidence includes security questionnaire, SOC 2 or ISO 27001 report when available, data processing agreement, retention policy, incident notification terms, subcontractor list, and access removal plan. If the vendor stores exported data, the retention period and deletion method must be documented.

Access must be least privilege, time-bound, logged, and reviewed every ninety days. Production access must use named accounts or approved service principals. Shared accounts are not allowed. Any exception requires security director approval.